PORTAL STUDIO · סקירת מידע ואבטחה

איפה יושב המידע שלך — ומי שומר עליו

סקירה בשפה פשוטה של כל המידע במערכת: איפה הוא מאוחסן, כמה הוא מוגן, מה כבר נסגר, ומה המצב מבחינת חוק ופרטיות.

- יסודות אבטחה חזקים
- הפערים המרכזיים נסגרו
- מנגנון מחיקת מידע פעיל
- חוקיות: טיוטות ממתינות לעו"ד

1 איפה הכל מאוחסן — 3 מקומות

כל המידע במערכת יושב באחד משלושה מקומות, כולם בענן על Railway בשרתים באמסטרדם (אירופה).

מסד הנתונים הראשי

PostgreSQL

הלב של המערכת: משתמשים, עסקים, שיחות, אנשי קשר, לידים, פגישות, חשבוניות ומנויים.

Railway · אמסטרדם (EU)

קבצים לכל עסק

אחסון קבצים

מסמכי הידע והקונטקסט שכל עסק מעלה. כל עסק בתיקייה מבודדת משלו.

דיסק מוצמד ב-Railway

תור זמני

Redis

לא מאחסן מידע קבוע — רק תור משימות זמני. מתרוקן מעצמו.

Railway · מוגן בסיסמה

2 איזה מידע נשמר — וכמה הוא מוגן

כל המידע מחולק לשלוש קבוצות. העמודה מימין מציינת את רמת ההגנה של כל פריט.

- מוצפן — AES-256
- מגובב (חד-כיווני) — סיסמאות
- גלוי בבסיס הנתונים — מוגן בשכבות הגישה

סוג המידע	מה זה כולל	איפה	רמת הגנה
א · מידע של המערכת עצמה			
חשבונות משתמשים	אימייל, שם, תפקיד, סטטוס	PostgreSQL	גלוי
סיסמאות	הסיסמה עצמה לא נשמרת — רק טביעה מתמטית שלה	PostgreSQL	מגובב bcrypt
הגדרות פלטפורמה	קטלוג סוכנים, תבניות מסמכים, אוטומציות, הרשאות	PostgreSQL	גלוי
ב · מידע שמצטבר לפי השימוש			
שיחות והודעות	תוכן השיחות בין הלקוחות לסוכן (וואטסאפ + צ'אט)	PostgreSQL	גלוי
לידים ופניות	טלפון, אימייל, תחום עניין, תשובות משאלון	PostgreSQL	גלוי
פגישות ותורים	מועדים, אנשי קשר, רשימת המתנה	PostgreSQL	גלוי
חיוב וכספים	חשבוניות, מנויים, מסלול תמחור, הוצאות	PostgreSQL	גלוי
יומן פעולות (Audit)	מי עשה מה ומתי — למעקב ואבטחה	PostgreSQL	גלוי
ג · מידע של בעלי העסקים והלקוחות שלהם			
פרופיל העסק	שם, מיתוג, טלפון בעל העסק, הגדרות סוכן	PostgreSQL	גלוי
אנשי קשר (לקוחות הקצה)	טלפון ואימייל של הלקוחות של כל עסק	PostgreSQL	גלוי
חיבור וואטסאפ	מפתח הגישה (Token) של ה-WhatsApp של העסק	PostgreSQL	מוצפן

סוג המידע	מה זה כולל	איפה	רמת הגנה
חיבורי גוגל (Gmail/יומן)	אסימוני גישה לחשבון הגוגל של העסק	PostgreSQL	מוצפן
חשבונית ירוקה	פרטי הגישה למערכת הסליקה/חשבוניות	PostgreSQL	מוצפן
מסמכי ידע של העסק	קבצים שהעסק מעלה + הוראות מפעיל נסתרות	אחסון קבצים	גלוי · מבודד לעסק

3 רמת האבטחה — שכבות ההגנה

היסודות בנויים נכון, והפערים שזוהו נסגרו.

סיסמאות בלתי הפיכות
חזק. סיסמאות משתמשים נשמרות מגובבות (bcrypt) בלבד. אף אחד, כולל אתה, לא רואה אותן.

מפתחות של לקוחות מוצפנים
חזק. טוקנים של וואטסאפ, גוגל וחשבונית ירוקה מוצפנים בתקן AES-256 לפני שהם נכנסים לבסיס הנתונים.

הפרדה מלאה בין עסקים
חזק. עסק אחד לא יכול לגשת למידע של עסק אחר, וגם לא לתיקיית הקבצים שלו.

חיבור מבודד לבסיס הנתונים
מכוסה. החיבור ל-Postgres עובר ברשת הפנימית הפרטית של Railway, מבודד מהאינטרנט הציבורי.

כלי ניהול ה-DB נסגר
טופל. כלי הניהול (Adminer) לא נגיש יותר מבחוץ — אין ממשק ניהול חשוף בפרוד.

נעילת ווידג'ט הצ'אט לדומיינים מאושרים
טופל. הווידג'ט רץ רק בדומיינים שהעסק אישר; ניסיון מאתר לא מורשה נחסם, וזיהוי דומיין חדש מעלה התראה.

תוכן שיחות ופרטי לקוחות — גלויים בבסיס הנתונים

לשיקול. נשמרים בצורה גלויה, מוגנים בשכבות הגישה סביבם. תקין ונפוץ; הצפנה ברמת הפריט היא שכבה נוספת אפשרית לעתיד.

4 חוקיות ופרטיות — איפה אתה עומד

אתה מחזיק מידע אישי של אנשים, ולכן חלים עליך שני חוקים עיקריים.

IL חוק הגנת הפרטיות (ישראל)

טיוטות מוכנות

המערכת מאחסנת טלפונים, אימיילים ותוכן שיחות — מאגר מידע לכל דבר, בכפוף לתיקון 13. אמצעי האבטחה (בקרת גישה, הצפנת סודות, יומן, הפרדה בין לקוחות) מיושמים, וזכות המחיקה ("להישכח") נתמכת. הוכנו טיוטות מדיניות פרטיות ו-DPA — ממתינות לאישור עו״ד.

GDPR EU (אירופה)

השרתים באמסטרדם — יתרון לשמירת מידע באיחוד. מידע שנשלח לעיבוד מחוץ לאיחוד (למשל תוכן הודעה לסוכן ה-AI של Anthropic/Claude) מגובה במנגנוני הגנה מקובלים ומגולה במדיניות הפרטיות.

⚠ **הבהרה:** זו אינה חוות דעת משפטית. הבסיס הטכני והמסמכים מוכנים, אך האישור הסופי לפני עלייה עם לקוחות בהיקף צריך לעבור דרך עו״ד המתמחה בהגנת הפרטיות.

5 מה כבר נסגר ✓

הפערים בעדיפות גבוהה טופלו, והשינויים חיים בפרודקשן.

1 **מנגנון מחיקת מידע (זכות להישכח)**

מחיקת לקוח בודד + כל המידע שלו, ומחיקת עסק שלם עם חלון שחזור של 30 יום. פעיל בפרוד.

✓ חי

2 **חיבור מבודד לבסיס הנתונים**

התעבורה ל-Postgres ברשת פרטית של Railway; נוספה גם תמיכת SSL בקוד כרשת ביטחון לעתיד.

✓ מכוסה

3 **סגירת כלי הניהול (Adminer)**
אין יותר ממשק ניהול DB חשוף בפרודקשן.
✓ בוצע

4 **נעילת ווידג'ט הצ'אט + ניטור**
הווידג'ט נעול לדומיינים מאושרים, עם התראה על דומיין חדש/חסום.
✓ חי

5 **מסמכים משפטיים — מדיניות פרטיות + DPA**
טיוטות מלאות ומותאמות למערכת (כולל ספקי המשנה). ממתינות לאישור עו״ד.
✓ טיוטה

6 מה נשאר

אף אחד מהם לא חוסם. הראשון הוא היחיד שאינו בידיים שלנו.

1 **אישור עו״ד לטיוטות המשפטיות**
העברת מדיניות הפרטיות וה-DPA לבדיקת עו״ד פרטיות, ואז פרסום בפועל.
שלב הבא

2 **לשקול הצפנה גם לפרטי לקוחות רגישים**
שכבת הגנה נוספת על טלפונים/אימיילים ותוכן שיחות — לא חובה, אבל מחזק.
עדיפות בינונית
